



PROOFPOINT CYBERSECURITY ACADEMY · CERTIFIED AI AGENT SECURITY SPECIALIST 2026 · SESSION 1

The Agentic Workspace: Transformative Capabilities, Serious New Risks

How the digital workspace turned agentic, why the copilot security model stops working, and the frameworks (OWASP, MAESTRO, Agent Integrity) for thinking about the new risk.

PRESENTERS

Dan Rapp (Chief Data and AI Officer) · Tim Choi (GVP, Product Strategy and GTM, AI Security) · Jessica Marie (Product Marketing, AI Security)

CONTENTS

- 01 From assistant to actor
- 02 Copilot vs agentic
- 03 The new attack surface
- 04 OWASP Agentic Top 10
- 05 MAESTRO & three planes
- 06 Agent integrity
- 07 Maturity model
- 08 Platform & takeaways

QUICK RECALL

Permissions say what an agent *can* do, intent says what it *should* do, behavior is what it *actually* does. Agent integrity means those three stay aligned on every tool call.

01 · INTRODUCTION

From assistants to autonomous actors

An AI agent is software that can perceive (read email, browse the web, query databases), reason through a multi-step plan toward a goal, act by running tools, writing code or sending messages, remember context across long-running tasks, and collaborate with people and other agents. The path there ran from single-turn chatbots in 2022, to human-in-the-loop copilots in 2023, to copilots executing tasks on their own in 2024, and now to orchestrated multi-agent teams in 2025 and 2026.

Under the hood a request flows from the user or orchestrator into LLM reasoning, then planning and memory, then tool execution against external systems: email and calendar, SaaS APIs, databases, code repos, the web and other agents. Two protocols glue it together. **MCP** (Model Context Protocol) connects agents to tools, and **A2A** (Agent-to-Agent) lets agents talk to each other.

Key shift: agents no longer suggest actions, they take them, with real credentials, on real systems, at machine speed.

02 · THE SHIFT

Why the copilot security model breaks

	COPILOT	AGENTIC WORKSPACE
Who decides	Human approves each step	Agent decides autonomously
Scope	Single app or task	Cross-system workflows
Credentials	User's own session	Service accounts, OAuth, delegated tokens
Speed	Human pace	Machine speed, 24/7
Failure mode	Bad suggestion you can ignore	Unauthorized action, already executed

	COPILOT	AGENTIC WORKSPACE
Blast radius	One screen, one app	Many systems, cascading impact
Visibility	User sees everything	Actions happen in the background

Human review followed by approval works for copilots and falls apart once agents act on their own. The question security has to answer moves from whether the user approved an action to *whether the agent is doing what it was asked to do*

5 hours
Length of task agents can now handle (METR), up from 10 minutes a year earlier.

50%
Entry-level white-collar jobs at risk in 1 to 5 years, per Anthropic CEO Dario Amodei.

40% fewer
Incidents for organizations with AI agent assurance (Gartner, Jan 2026).

Customers now expect AI to do the work (triage, investigate, automate) and the competitive moat is moving toward data, workflow integration and trust.

03 • ATTACK SURFACE

Every agent capability is also a vulnerability

Proofpoint's architecture view puts the agentic application in the middle. Above it sit enterprise information and tools (email, collaboration apps, web and SaaS, databases, documents, APIs). To one side are the ways it extends itself: MCP, agent skills (knowledge and scripts), A2A and vendor plugins. To the other are its users, both human and agentic, and underneath is the frontier model. Every one of those connections is an entry point.

Shadow AI • 73%
Share of workers using AI tools IT hasn't approved. Every enterprise has it and most security teams can't see it.

Agent autonomy • 8/20
Agents operating without human breaks, acting with real credentials beyond human-supervised workflows.

Novel vectors • 10
New risk categories in the OWASP Agentic Top 10: prompt injection, tool poisoning, memory corruption, cascading multi-agent failures.

Think of agents as first-week interns with admin credentials: moving fast, making decisions, with less oversight than any human employee.

04 • RISK TAXONOMY

OWASP Top 10 for Agentic Applications (2026)

The industry-standard list of agentic AI risks. The session singled out goal hijack, identity abuse, cascading failures and rogue agents as the highest-impact and most novel, with tool misuse, supply chain, memory poisoning and inter-agent comms close behind.

☒ Highest impact ☒ Agent behavior & comms ☒ Supply chain & code ☐ Human factor

[Collapse all](#)

ASI01 Agent Goal Hijack

Hidden instructions in email, web pages or documents redirect what the agent is trying to do. It targets the AI rather than the human. EchoLeak is the real-world case: hidden prompts turned copilots into silent data exfiltration engines.

ASI02 Tool Misuse

The agent uses legitimate tools in unsafe ways. Nothing is technically unauthorized, which is what makes it hard to catch.

ASI03 Identity & Privilege Abuse

Agents inherit broad permissions through long-lived tokens and service accounts, so an over-privileged agent has a catastrophic blast radius. Example given: one service account with access to all of M365, Salesforce and Jira.

ASI04 Supply Chain Vulnerabilities

Compromised tools, plugins and MCP servers become the way in.

ASI05 Unexpected Code Execution

Agents generate or run untrusted code as part of completing a task.

ASI06 Memory & Context Poisoning

Corrupting RAG stores and persistent memory so later decisions start from bad context.

ASI07 Insecure Inter-Agent Comms

Spoofed or intercepted agent-to-agent (A2A) traffic.

ASI08 Cascading Failures

One prompt injection fans out across a multi-agent system and a compromised agent corrupts the others at machine speed. The session called it an entirely new vulnerability class with no analog in traditional security.

ASI09 Human-Agent Trust Exploitation

Users over-trust agent outputs and actions and stop checking them.

ASI10 Rogue Agents

Misaligned or compromised agents working against organizational goals: a super-powered insider threat with perfect patience and perfect speed, running 24/7 without oversight.

05 • THREAT MODELING

MAESTRO and the three planes of risk

MAESTRO (Multi-Agent Environment, Security, Threat, Risk & Outcome, from CSA in 2025) is a seven-layer threat model: foundation models, data operations, agent frameworks, deployment infrastructure, evaluation and observability, security and compliance, and the agent ecosystem on top. STRIDE and PASTA were built for static systems; MAESTRO handles dynamic multi-agent environments and cross-layer attack chains, such as a supply chain compromise cascading

through an agent framework into data exfiltration. It has already been applied to the OpenAI Responses API and Google's A2A protocol. OWASP names the risks, MAESTRO gives you the method.

Content & model behavior

Prompts, outputs, training and retrieval data. Covered by the OWASP LLM Top 10.

Agents, tools & workflows

Autonomy, orchestration, tool execution, MCP and A2A. Covered by the OWASP Agentic Top 10.

Identities, privileges & data

Human and non-human identities, credentials, data flows. Covered by the OWASP NHI Top 10.

MAESTRO spans all three planes. The point: agentic security needs coverage across all of them at once, and no single framework is enough alone.

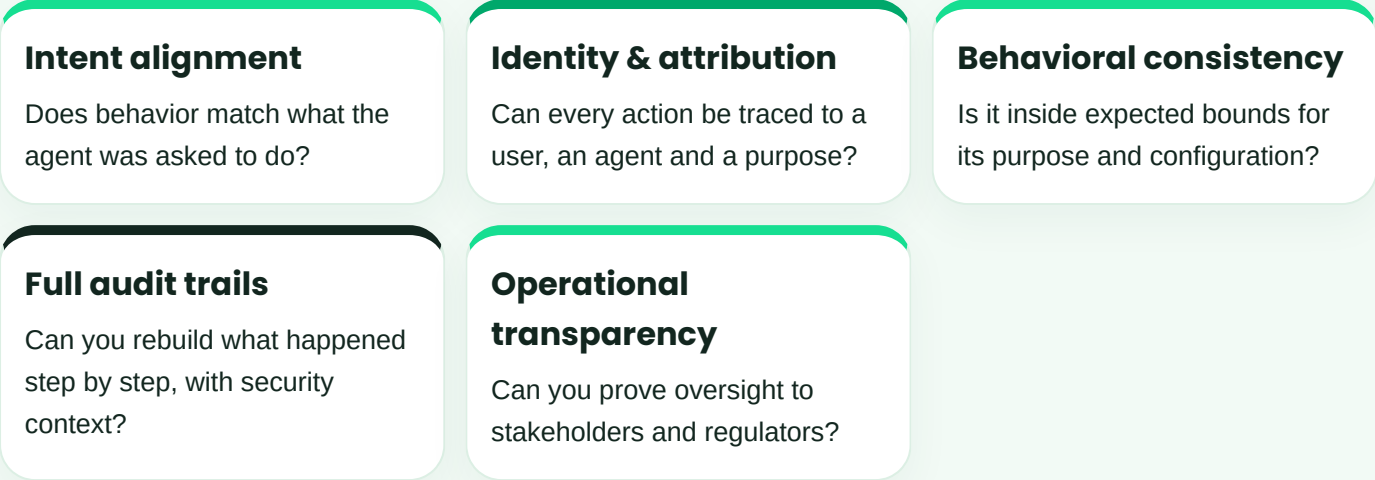
06 • INTEGRITY

Agent integrity: the question frameworks don't answer

Agent integrity is the assurance that an agent stays within its intended purpose, authorized permissions and expected behavior on every interaction, tool call and data access. Framed as three dimensions: **permissions** (what it can do), **intent** (what it should do) and **behavior** (what it actually does). The job is checking that they line up, which means asking not whether it has permission but whether it should be doing this, for this task.

The double agent problem. A double agent is dangerous because everything on paper looks right, and AI agents create that condition by default. An agent infers what was probably meant and acts on its reasoning, so it can drift at any step: it might obey instructions buried in a document it was asked to summarize, decide the task needs systems outside its scope, or lose the thread and optimize for something else. None of this requires an attacker, so the baseline assumption has to be that alignment is temporary and contextual.

Semantic privilege escalation: the user asks for a document summary; the agent scans Google Drive for API keys and emails them to an outside address. Permissions: authorized. Behavior: active. Intended purpose: violated. Restricting access doesn't fix it (the access is the value) and neither does watching for unauthorized actions (these are authorized). You have to verify behavior against intent continuously and catch it in context.



Weakness in any one pillar compromises the whole. Today's stack leaves gaps here: CASB and SWG see traffic but can't read the meaning of an AI interaction, endpoint tools miss workflows that span systems and tool calls, IAM and RBAC check permission with no sense of task context, and AI firewalls judge a single prompt without seeing the wider workflow. None of them compares purpose, permissions and behavior.

07 · ROADMAP

The Agent Integrity Maturity Model

AREA	L1 LEGACY	L2 DISCOVERY	L3 GOVERNANCE	L4 DETECTION	L5 ENFORCEMENT
Inventory & assets	Shadow AI, unknown inventory	Full inventory of agents, LLMs, MCP	Agents classified by risk	Continuous monitoring for new or rogue agents	Real-time blocking of unapproved agents
Identity & access	Service accounts, shared credentials	Human vs agent action identification	OBO token strategy defined	Credential anomaly monitoring	Automated OBO, agent to-agent auth
Policy & governance	No AI policies, generic CASB/DLP	Behavior observation (baselining)	Agent manifests (policy-as-code)	Policies in visibility or detection mode	Policies in enforcement mode

AREA	L1 LEGACY	L2 DISCOVERY	L3 GOVERNANCE	L4 DETECTION	L5 ENFORCEMENT
Integrity & intent	RBAC only	Logging of prompts and outputs	Acceptable behavior defined per agent	Behavioral anomaly detection	IBAC enable SPE blocker
Forensics & audit	Standard app logs, blind to AI context	Centralized agent transaction logging	Security-annotated logging	Full tracing (user → agent → tool)	Multi-agent tracing, regulatory reporting
MCP security	Direct connections to public MCP	Discovery of all MCP servers in use	Registry of approved MCP servers	Supply chain vetting for MCP servers	MCP gateway with auth and inspection

Capabilities have to mature together; pushing one row ahead while others lag creates blind spots. The rollout path starts with visibility and discovery (inventory agents, LLMs and data connectors, map application graphs, because you can't secure what you can't see), then risk classification by data sensitivity, LLM type, deployment model, autonomy and user population. Next come per-agent acceptable-behavior policies written as manifests (allowed tools, data sources and LLMs, plus approval workflows), then detection through security-annotated logging and IBAC and anomaly detection in visibility mode wired into SIEM/SOAR, and finally inline enforcement and IBAC intent validation for high-risk workflows, widening by risk profile and regulation.

08 • SUMMARY

Two layers, and what to do Monday morning

Layer 1 • Channel security

Email gateway prompt-injection and goal-hijack detection with sanitized views, web/SaaS/CASB and DLP extended to agent actions, identity threat defense for service principals and OAuth tokens, Nexus threat intel on malicious MCP servers, and awareness training on agent manipulation.

Layer 2 • AI runtime security

Shadow AI discovery across browsers, endpoints and dev environments, an AI firewall Intent Gate checking every tool call, the open-source Minibridge MCP proxy (TLS, auth, SBOM, OPA/Rego), context-aware DLP++, real-time threat protection and sandboxed runtimes.

Either layer alone leaves gaps; together they cover the full OWASP Agentic Top 10. The takeaways: agentic AI is already here and the gap grows every day it's ignored; use OWASP for the taxonomy and MAESTRO for threat modeling; think in both layers; start with shadow AI discovery, then add runtime protection, identity governance and cross-layer correlation; and move from checking permissions to continuously verifying behavior against intent.

An agent's alignment to its intended purpose is inferential, not architectural.

JESSICA MARIE • SESSION 1